

Forma **TEC**

CLASE 4

Seguridad en capas



Previamente

Recordemos

Comentarios o dudas sobre la última clase:

- DRP

Fundamento

Cuanto más mejor

Defensa en Profundidad: Asegurando la Nube Moderna

Estrategias avanzadas para
Contenedores, Kubernetes y
Detección de Amenazas.

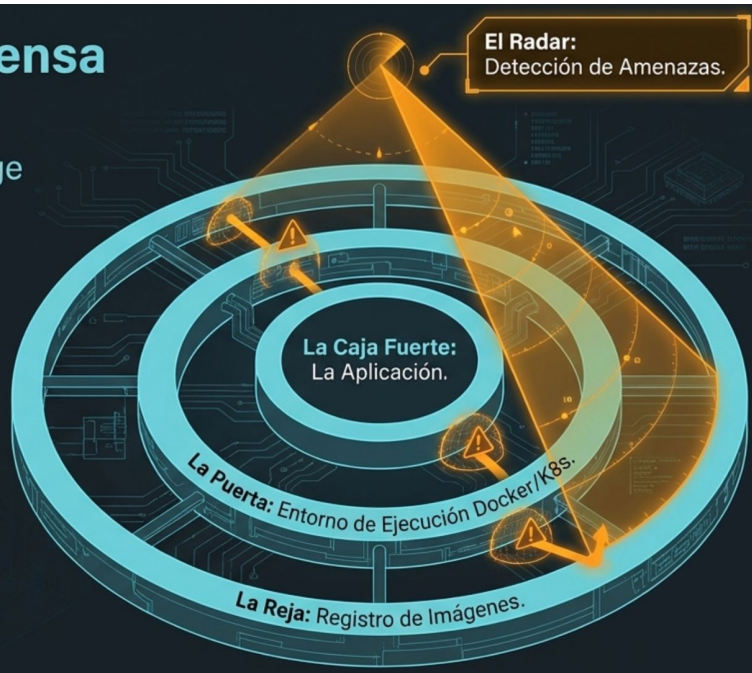
Fundamento

La filosofía

La filosofía de la Defensa en Profundidad

En la nube, la confianza cero exige capas superpuestas. Si una capa es vulnerada, la siguiente debe neutralizar el ataque.

"No confiamos en una sola cerradura; ponemos una en la reja, otra en la puerta y una en la caja fuerte."



Fundamento

La razón

El talón de Aquiles de la infraestructura containerizada

Un contenedor comparte el núcleo (kernel) del sistema operativo anfitrión. Si la armadura falla, el compromiso es total.



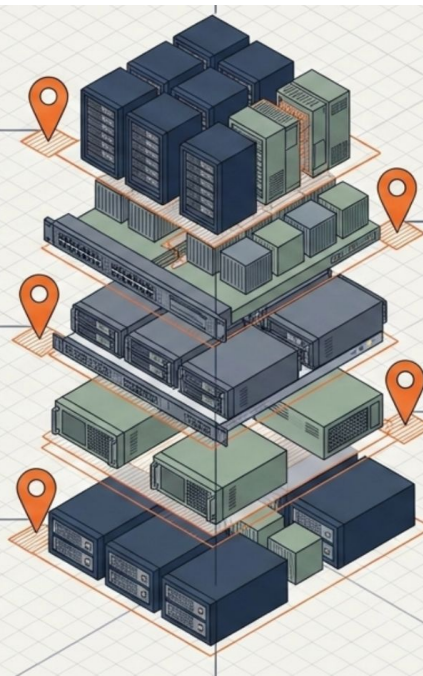
Fundamentos

Los 5 puntos a revisar

1. **Configuraciones por defecto:** Privilegios excesivos en controles de acceso.

2. **Seguridad del Host:** El cimiento subyacente de la arquitectura.

3. **Imágenes:** Puntos de infiltración en la cadena de suministro.

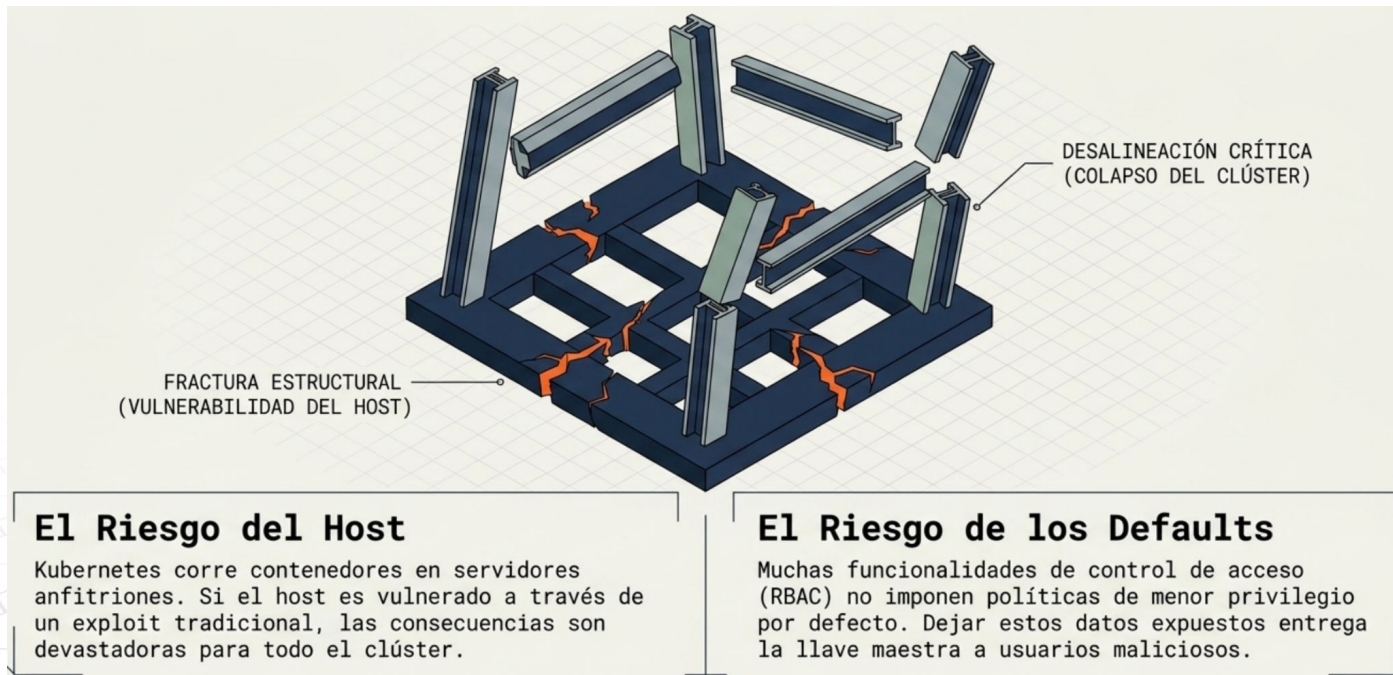


4. **Container Runtime:** El punto ciego de Kubernetes durante la ejecución.

5. **Comunicaciones Pod-to-Pod:** El riesgo de movimiento lateral interno.

Fundamento

Los riesgos del host



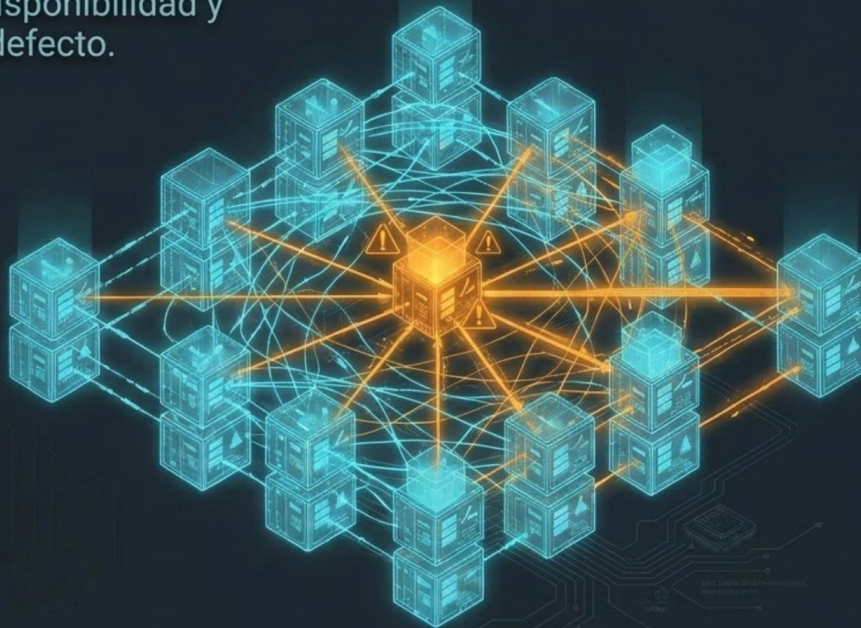
Fundamento

Container runtime

Kubernetes y Docker priorizan la disponibilidad y conectividad, no la seguridad por defecto.

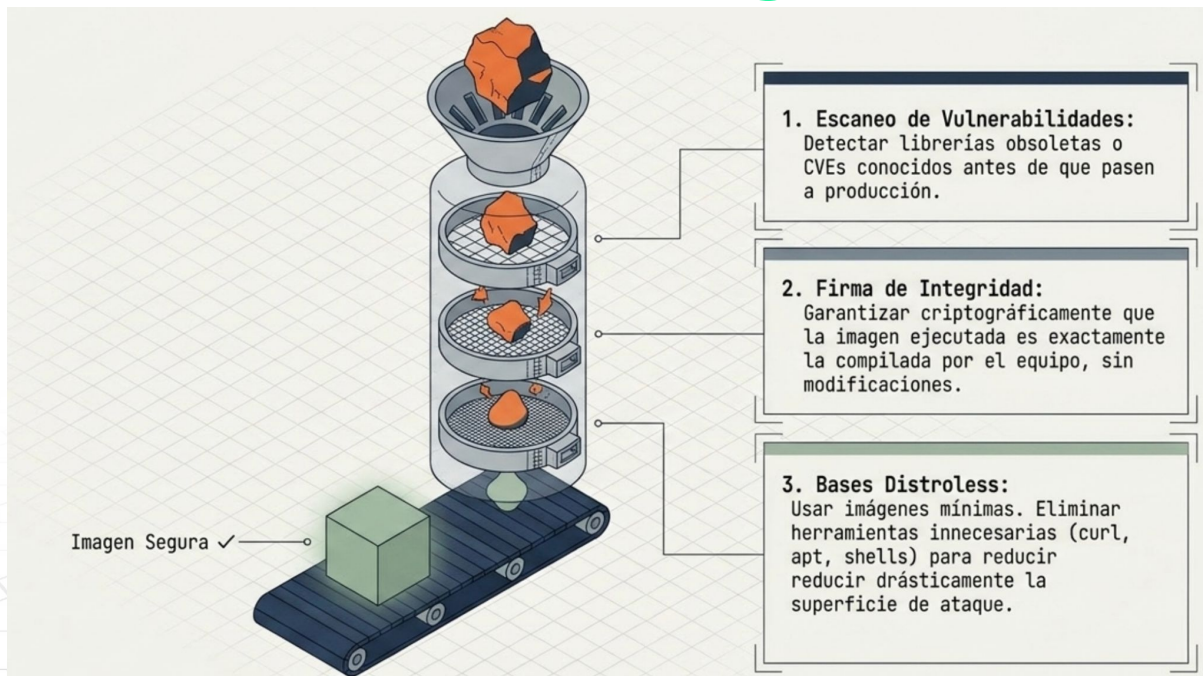
Las falsas sensaciones de seguridad:

- Las políticas de red no existen por defecto; los pods pueden comunicarse libremente.
- No existen protecciones nativas contra ataques en runtime.
- No se pueden detectar intrusiones activas una vez que ocurren.



Fundamento

Seguridad en la imagen

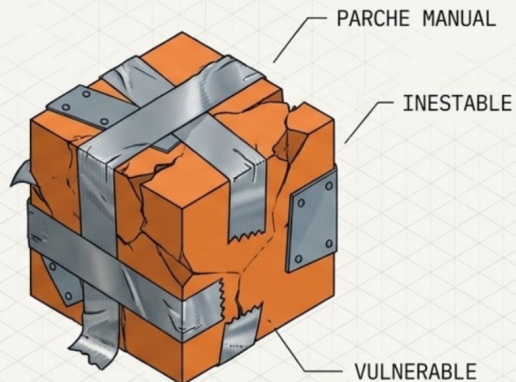


Fundamento

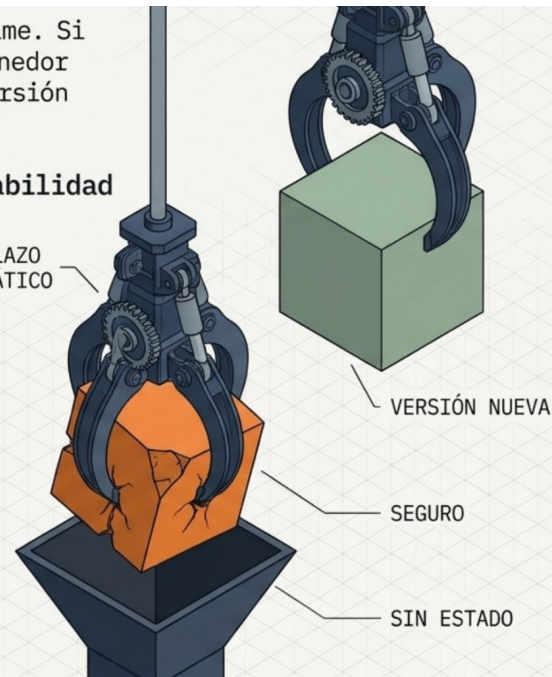
Inmutabilidad

Kubernetes no tiene protecciones contra ataques en runtime. Si se detecta una brecha activa, jamás se parchea el contenedor en ejecución. Se debe terminar entero y desplegar una versión nueva.

Mala práctica



Inmutabilidad



Fundamento

Contención del radio

Contener el radio de explosión limitando el consumo y el acceso a la red interna.

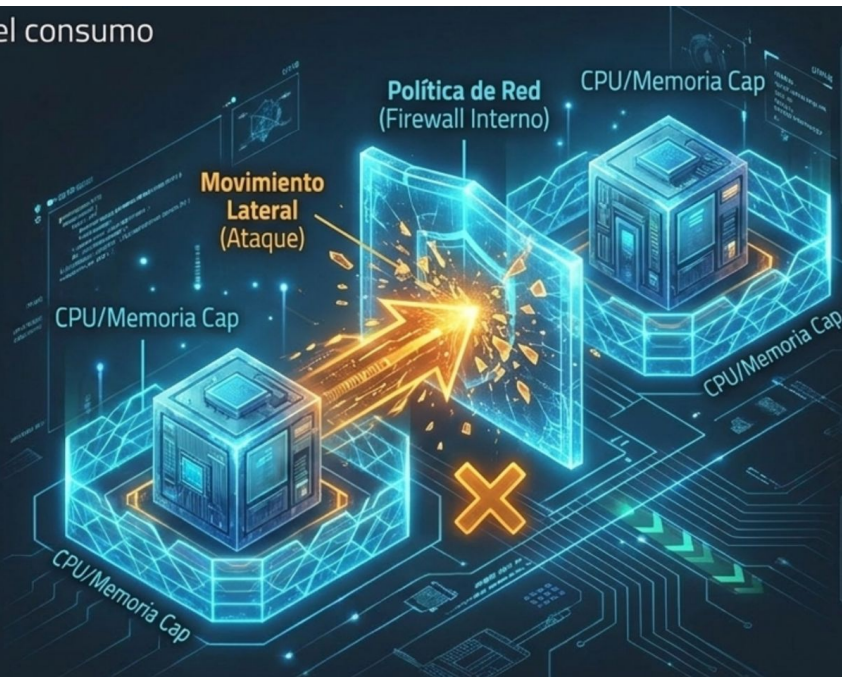
Limitación de Recursos

Prevenir ataques de Denegación de Servicio (DoS) internos estableciendo techos estrictos de CPU y Memoria. (Regla #7)



Políticas de Red (K8s)

Actuar como un firewall interno, restringiendo la comunicación pod-to-pod únicamente a los activos definidos. (Regla #5)



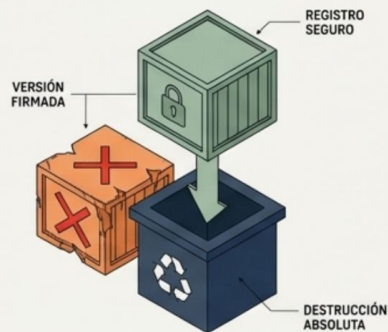
Fundamento

Reglas de oro

01

INMUTABILIDAD

Nunca modificar en ejecución. La solución a una brecha es la destrucción absoluta y el redespigüe desde el registro seguro.

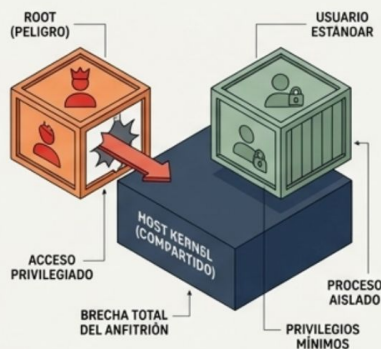


CICLO DE VIDA:
DESPLIEGUE > EJECUCIÓN > REEMPLAZO

02

NO ROOT

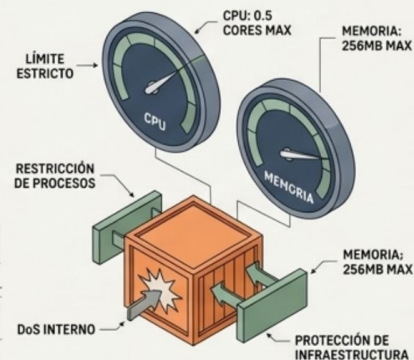
Jamás ejecutar procesos como administrador. Los contenedores comparten el kernel; un atacante como root tomará control total del servidor anfitrión.



03

LIMITAR RECURSOS

Restringir estrictamente CPU y Memoria asignada. Previene ataques de Denegación de Servicio (DoS) internos que pueden derribar la infraestructura.



Fundamentos

Vigilancia en AWS

	CloudTrail	GuardDuty
Metáfora	El Historial	La Inteligencia Vigilante
Naturaleza	Registro pasivo y continuo	Análisis activo mediante Machine Learning
Tecnología Core	Logs de API inmutables (inborrables, incluso para admins)	Detección de amenazas en tiempo real y anomalías
Caso de Uso Clave	Auditoría Forense: ¿Quién borró la base de datos el domingo a las 3 AM?	Detección Activa: Actividad inusual, minería de criptomonedas, o intrusiones.

El futuro

Tercera capa: IA

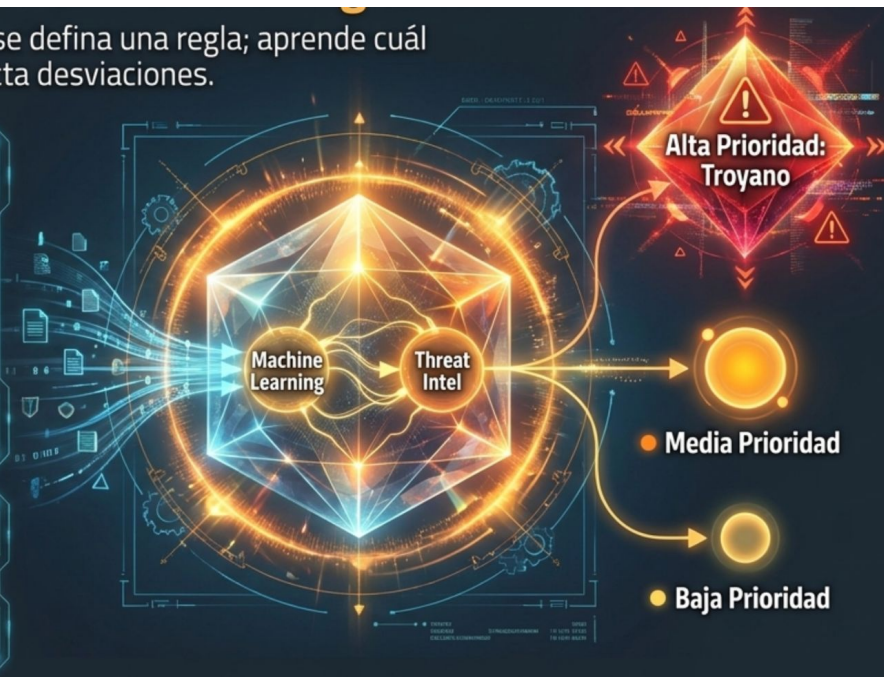
Amazon GuardDuty no espera a que se defina una regla; aprende cuál es el comportamiento normal y detecta desviaciones.

Motores de Detección:

- **Inteligencia de Amenazas:** Bases de datos actualizadas de IPs maliciosas y dominios conocidos (CrowdStrike, Proofpoint).
- **Machine Learning:** Modelos entrenados para detectar anomalías (ej. patrones inusuales de inicio de sesión o exfiltración DNS).

Clasificación de Hallazgos (Findings):

Baja, Media y Alta Prioridad (Ej: Detección de ataque de troyano de alta severidad o minería de criptomonedas).



Cierre

Preguntas o Dudas

La Seguridad es un Proceso, no un Producto

La defensa en profundidad requiere un ciclo continuo de despliegue inmutable, vigilancia inteligente y adaptación estructural.
La seguridad no se instala; se cultiva.

Próximos pasos

Manos a la obra

Herramientas o apps

- Demostración K8s